

ResolvX

Backup & Recovery Policy

Topic-Specific Policy - Data Backup, Restoration & Recovery Assurance

POL-009 · v1.0 · 2026 · Internal : Restricted

Document Information

Policy ID	POL-009
Version	1.0
Status	Active
Classification	Internal - Restricted
Owner	Head of Cloud Ops
Approver	CISO
Review Cycle	Annual, or upon material infrastructure change
Next Review	Q3 2027
Frameworks	ISO 27001:2022 A8.13 · NIST CSF 2.0 PR.DS-11, RC.RP-03 · SOC 2 A1.2

1. Purpose

This Backup & Recovery Policy establishes ResolvX's requirements for backing up business-critical data and systems, protecting those backups, and verifying that they can be restored within the recovery objectives clients and regulators expect.

Reliable, tested backups are what make the recovery time and recovery point objectives in the Business Continuity & Disaster Recovery Policy (POL-008) achievable rather than aspirational. This policy defines how those backups are taken, protected, retained, and critically proven to work through regular restoration testing.

This policy satisfies ResolvX's obligations under ISO 27001:2022 A8.13 (Information backup) and supports the RTO/RPO commitments made to clients under SOC 2 Availability criteria.

2. Scope

This policy applies to all systems and data classified Restricted or Confidential under the Data Classification Policy (POL-004), including:

- The production database cluster (Amazon RDS, PostgreSQL).
- Production object storage (Amazon S3).
- Infrastructure configuration and application source code.
- Staging environment data, at a reduced service level relative to production.

Development environment data is explicitly out of scope, as it holds only synthetic, non-production data.

3. Backup Requirements by Criticality Tier

Backup frequency and retention are set to achieve the Recovery Point Objectives (RPO) already defined in POL-008's Business Impact Analysis:

Criticality Tier	Systems	Backup Method	Frequency	Target RPO
Critical	RDS production database	Automated snapshots + continuous point-in-time recovery	Continuous (PITR) + daily snapshot	15 minutes
Critical	Secrets & IAM configuration	Versioned, encrypted configuration store	On every change	Near-zero
High	S3 production object storage	Versioning enabled	Continuous (on write)	1 hour
High	Infrastructure-as-code / application source	Git version control	On every commit	1 hour
Medium	Staging environment	Automated snapshot	Daily	24 hours
Low	Development environment	Not formally backed up (synthetic data only)	N/A	Best effort

4. Current State

Automated RDS backups and Multi-AZ deployment are already in place for the production database, providing the technical foundation this policy formalises. This policy establishes the retention, protection, and the testing regime that turns that existing technical capability into a verified, audit-ready control.

5. Backup Protection & Retention

Requirement	Standard
Encryption	All backups encrypted at rest (AWS KMS) and in transit
Access	Restricted to Head of Cloud Ops and DevSecOps; no standing write/delete access for other roles
Immutability	RDS automated snapshots and S3 versioned objects are not directly deletable by application-layer credentials
Retention - Critical tier	35 days rolling (automated), plus one monthly snapshot retained 12 months for audit evidence
Retention - High tier	Object version history retained 90 days minimum
Retention - Medium tier	7 days rolling
Geographic protection	Cross-region replication for Critical-tier backups, tracked as a Target State item under POL-008 §4.2

Backups that reach the end of their retention period are securely deleted, not left to age indefinitely, AWS-native secure deletion for snapshots and versioned S3 objects satisfies this requirement without a separate manual process.

6. Restoration Testing

6.1 Backup Job Monitoring

A scheduled backup that fails silently is worse than no backup at all, because it creates false confidence. Every automated backup job (RDS snapshot, S3 versioning health, staging snapshot) is monitored for successful completion, and a failed or skipped job generates an alert to Head of Cloud Ops the same day, not discovered at the next restoration test.

6.2 Restoration Test Cadence

A backup that has never been restored is not a verified control. Restoration testing is performed on the following cadence, consistent with POL-008 §8:

Test	Frequency	Owner	Evidence
Critical-tier restoration test (RDS)	Quarterly	Head of Cloud Ops	Test log retained by GRC Lead
High-tier restoration spot-checks (S3)	Quarterly	Head of Cloud Ops	Test log retained by GRC Lead

Test	Frequency	Owner	Evidence
Full DR failover exercise (all tiers, combined with POL-008)	Annual	VP Engineering / Head of Cloud Ops	DR Failover Tabletop Test Report

Each restoration test measures actual time-to-restore against the target RPO/RTO in §3 and POL-008 §3. Any test that fails to meet its target is logged as a Corrective Action Plan item, with a remediation owner and date.

6.3 Backup Integrity Verification

A successful restore is not, by itself, proof the backup was good. The restored data must also be verified as complete and uncorrupted. Every quarterly restoration test includes an integrity check (row-count / checksum comparison against a known-good baseline for the RDS restore; object-count and spot-check comparison for S3), and any discrepancy is treated as a failed test, not a partial success.

6.4 Ransomware Resilience - Immutable Backup Copy

Standard backups are protected against accidental deletion (§5), but a compromised credential with production access could still target both live data and its backups if they share the same trust boundary. Critical-tier backups (RDS snapshots) therefore maintain at least one copy that is not deletable or modifiable by any credential used in day-to-day operations which is enforced through separate access controls or a retention lock, so that a ransomware event or insider compromise cannot remove the recovery path.

7. Roles & Responsibilities

7.1 Head of Cloud Ops

- Owns backup configuration, scheduling, and encryption for all in-scope systems.
- Executes restoration tests on the cadence defined in §6.
- Escalates any failed restoration test to VP Engineering and the CISO.

7.2 DevSecOps

- Maintains infrastructure-as-code and source control backup integrity (§3).

7.3 GRC Lead

- Retains restoration test evidence and the DR Failover Tabletop Test Report.
- Logs any missed RPO/RTO target as a Corrective Action Plan item.

7.4 CISO

- Approves this policy and any change to retention or encryption standards.

8. Compliance and Enforcement

Failure to execute a scheduled restoration test, or unauthorized deletion or modification of backup data, is treated as a control deficiency and logged in the Corrective Action Plan.

9. Document Control

Policy ID	POL-009
Version	1.0
Status	Active
Classification	Internal - Restricted
Owner	Head of Cloud Ops
Approver	CISO
Review Cycle	Annual, or upon material infrastructure change
Next Review	Q3 2027
Framework References	ISO/IEC 27001:2022 A8.13 · NIST CSF 2.0 PR.DS-11, RC.RP-03 · SOC 2 TSC A1.2
Related Documents	POL-001 (Information Security Policy), POL-004 (Data Classification Policy), POL-008 (BCP/DR Policy & Plan), DR Failover Tabletop Test Report (evidence artifact)

ResolvX GRC Program — Internal Use Only — v1.0 — 2026

Authorisation

Role	Name	Date
CEO		
CISO		
GRC Lead		